

RAPPORT D'ANALYSE FORENSIQUE

Autopsie d'une image disque — Machine HASAN2

Investigation numérique menée avec Autopsy 4.18.0

Enquêteur : dimisan221

Environnement : TryHackMe — Disk Analysis

Classification : Confidentiel

Date : 18 Juillet 2026

AVERTISSEMENT : ce document est un rapport d'investigation numérique rédigé dans un cadre strictement éducatif (exercice TryHackMe). L'image disque analysée est fournie dans un environnement de laboratoire dédié. Les méthodes décrites ne doivent être appliquées que dans le cadre d'investigations autorisées.

Sommaire

1. Résumé exécutif
2. Informations sur le dossier
3. Preuve numérique et chaîne de possession
4. Méthodologie
5. Résultats de l'analyse
6. Chronologie synthétique
7. Indicateurs de compromission
8. Conclusion

1. Résumé exécutif

Ce rapport présente les résultats d'une investigation numérique (analyse post-mortem) menée sur une image disque au format E01 extraite d'un poste de travail Windows 10, dans le cadre d'un exercice pédagogique de type CTF (TryHackMe).

L'analyse, réalisée avec l'outil Autopsy 4.18.0, a permis d'identifier les éléments suivants :

- Les informations d'identification du système (nom d'hôte, adresse IP, adresse MAC, carte réseau).
- La liste complète des comptes utilisateurs locaux et le dernier utilisateur connecté.
- Un logiciel de surveillance réseau installé sur la machine (Look@LAN).
- Des traces d'activité utilisateur : favori Google Maps, fond d'écran personnalisé, historique PowerShell.
- La présence de deux outils offensifs ciblant les mots de passe (LaZagne et Mimikatz), ainsi qu'une règle YARA de détection associée.
- Des preuves d'une élévation de privilèges réalisée localement par un utilisateur, avec dépôt d'un fichier de compromission sur le bureau du propriétaire de la machine.

Niveau de risque global : **ÉLEVÉ**

2. Informations sur le dossier

Adresse IP de la cible	10.129.185.70
Compte fourni	administrator
Outil d'investigation	Autopsy 4.18.0
Type d'image	E01 (EnCase Evidence File)
Nom du fichier image	img_HASAN2.E01

Note : le mot de passe du compte fourni pour l'accès à l'environnement n'est pas reproduit dans ce rapport, conformément aux bonnes pratiques de traitement des identifiants dans la documentation.

3. Preuve numérique et chaîne de possession

L'intégrité de l'image disque a été vérifiée par calcul de son empreinte MD5, permettant de garantir qu'aucune altération n'a eu lieu entre l'acquisition et l'analyse.

Propriété	Valeur
Nom de l'image	img_HASAN2.E01
Type	E01
Taille	65 433 829 376 octets (~ 61 Go)
Taille de secteur	512 octets
Fuseau horaire	America/New_York
Device ID	bc9ef60d-bb21-4d94-a08f-3c169aa07774
Hash MD5	3f08c518adb3b5c1359849657a9b2079

Le volume vol3 (NTFS / exFAT) a servi de source principale pour l'ensemble des artefacts présentés dans ce rapport.

4. Méthodologie

L'analyse a été conduite selon une approche classique d'investigation post-mortem (dead-box forensics), sans altération du support source :

- Chargement de l'image E01 en lecture seule dans Autopsy.
- Vérification d'intégrité par calcul de hash (MD5).

- Extraction et analyse des ruches de registre (SYSTEM, SAM, SOFTWARE) pour les informations système et les comptes utilisateurs.
- Analyse du système de fichiers utilisateur (bureau, téléchargements, favoris navigateur, historique PowerShell).
- Recherche de mots-clés et de fichiers d'intérêt (outils de piratage, règles YARA, scripts PowerShell).
- Reconstruction chronologique des actions de l'utilisateur à partir des métadonnées de fichiers (MACB timestamps).

5. Résultats de l'analyse

5.1 Informations système

Élément	Valeur
Nom du compte informatique	DESKTOP-6R59DJ3
Système d'exploitation	Windows NT, architecture AMD64
Adresse IP locale	192.168.130.216
Adresse MAC	08-00-27-2C-C4-B9
Carte réseau	Intel(R) PRO/1000 MT Desktop Adapter

5.2 Comptes utilisateurs

La ruche SAM a permis d'extraire l'ensemble des comptes locaux configurés sur la machine. Par ordre alphabétique :

- H4S4N, joshwa, keshav, sandhya, shreya, sivapriya, srini, suba

Le dernier utilisateur à s'être connecté à l'ordinateur, d'après la date d'accès la plus récente enregistrée dans la ruche SAM, est sivapriya.

5.3 Activité utilisateur

Un favori enregistré dans Google Maps depuis Firefox a été retrouvé dans la base places.sqlite, indiquant les coordonnées suivantes :

- 12°52'23.0"N 80°13'25.0"E

Le fond d'écran personnalisé de l'utilisateur joshwa affichait un nom complet imprimé sur l'image de bureau, permettant d'identifier le propriétaire du compte comme étant : Anto Joshwa.

5.4 Artefact PowerShell — modification d'un indicateur

L'historique PowerShell (ConsoleHost_history.txt) de l'utilisatrice shreya montre la modification manuelle d'un fichier texte présent sur son bureau :

```
Get-Content .\shreya.txt
Add-Content .\shreya.txt 'flag{HarleyQuinnForQueen}'
Get-Content .\shreya.txt
Set-Content .\shreya.txt 'flag{i_changed_it}'
exit
```

L'indicateur (flag) initialement présent dans le fichier était flag{HarleyQuinnForQueen}, avant d'être remplacé par flag{i_changed_it}.

5.5 Élévation de privilèges détectée

Un script PowerShell (exploit.ps1) retrouvé sur le bureau de shreya illustre une tentative d'élévation de privilèges, vérifiant l'appartenance au groupe Administrateurs (SID S-1-5-32-544) avant de déposer un fichier de preuve sur le bureau de l'utilisateur H4S4N :

```
if ([System.Security.Principal.WindowsIdentity]::GetCurrent().groups -match "S-1-5-32-544") {
    # Payload goes here
    New-Item "C:\Users\H4S4N\Desktop\hacked.txt"
    Add-Content C:\Users\H4S4N\Desktop\hacked.txt "flag{I-hacked-you}"
    ##### https://youtu.be/C9GfMtFjhYI
} else {
```

Le message adressé au propriétaire de l'appareil, déposé dans le fichier hacked.txt sur son bureau, était : flag{I-hacked-you}.

5.6 Outils offensifs identifiés

Deux outils connus de récupération de mots de passe ont été retrouvés dans les téléchargements de l'utilisateur H4S4N. Par ordre alphabétique :

- LaZagne
- Mimikatz (mimikatz_trunk.zip)

Un fichier de règle YARA (kiwi_passwords.yar) a également été retrouvé sur le système, ciblant la détection de Mimikatz. L'auteur identifié dans les métadonnées de la règle est : Benjamin Delpy (gentilkiwi).

5.7 Logiciel de surveillance réseau

Parmi les programmes installés recensés dans la ruche SOFTWARE, un outil de surveillance réseau a été identifié : Look@LAN (version 2.90 Build 35).

6. Chronologie synthétique

Date / Heure (EST)	Événement
2021-02-06 05:38:00	Création du compte joshwa (référence de comparaison des comptes utilisateurs).
2021-02-06 05:39:20 → 05:42:00	Création des comptes utilisateurs locaux (keshav, sandhya, shreya, sivapriya, srini, suba).
2021-02-06 09:56:28	Téléchargement des outils LaZagne et Mimikatz par H4S4N.
2021-02-06 10:05:17 → 10:05:22	Présence de la règle YARA de détection Mimikatz et de fichiers de résultats de recherche.
2021-02-06 12:40:10 → 12:40:36	Modification du fichier shreya.txt via PowerShell (remplacement du flag initial).
2021-02-07 12:05:37	Dernière connexion enregistrée : utilisatrice sivapriya (dernier accès observé sur le système).

7. Indicateurs de compromission

Type	Valeur	Sévérité
Fichier	mimikatz_trunk.zip	ÉLEVÉE
Fichier	lazagne (exécutable de récupération de mots de passe)	ÉLEVÉE
Script	exploit.ps1 — vérification SID Administrateurs (S-1-5-32-544)	ÉLEVÉE
Fichier déposé	C:\Users\H4S4N\Desktop\hacked.txt	MOYENNE
Logiciel	Look@LAN 2.90 (surveillance réseau non sollicitée)	FAIBLE

8. Conclusion

L'analyse forensique de l'image img_HASAN2.E01 met en évidence une activité malveillante interne : téléchargement et utilisation d'outils de récupération de mots de passe (LaZagne, Mimikatz), suivie d'une élévation de privilèges locale exploitée pour déposer un fichier de preuve sur le poste d'un autre utilisateur du système.

Ces éléments, combinés à la présence d'un outil de surveillance réseau installé sur la machine, suggèrent un scénario de compromission interne plutôt qu'une attaque externe directe.

Il est recommandé de renforcer la surveillance des comptes à privilèges, de restreindre les téléchargements d'outils non approuvés, et de mettre en place une détection (EDR/YARA) capable d'identifier la présence d'outils tels que Mimikatz sur le parc informatique.

Ce document a été réalisé dans un cadre pédagogique (TryHackMe) et ne constitue pas un rapport d'investigation légale opposable.